

Mobil Uygulama Güvenliđi

a) Ekran görüntüsü ve ekran kaydı

Bankacılık uygulamalarında hesap bakiyesi, kredi kartı numarası ya da transfer geçmişı gibi çok hassas veriler yer alıyor. Bazen arkada çalışan zararlı bir yazılım sessizce ekranımızı kaydediyor olabilir ya da biz yanlışlıkla bir ekran görüntüsünü başkalarıyla paylaşabiliriz. Bu tür durumlarda verilerin sızmasını önlemek hayati önem taşıyor.

Bunu engellemek için Android'de genelde FLAG_SECURE bayrađını kullanıyoruz. Uygulamanın ekranlarına bu kodu eklediğimizde, işletim sistemi o ekranın görüntüsünün alınmasına veya kaydedilmesine izin vermiyor, ekran direkt siyah çıkıyor. iOS tarafında ise doğrudan engellemek biraz daha zor olsa da, ekranın kaydedildiđini algılayıp ekrana blur atabiliyor veya uyarı çıkarabiliyoruz.

b) Overlay saldırıları

Overlay saldırısı, cihazdaki zararlı bir uygulamanın aslında tamamen farklı bir uygulamanın üstüne görünmez veya sahte bir katman çizmesiyle oluşuyor. Biz orijinal ve güvenli bir uygulamayı kullandığımızı sanıyoruz ama aslında dokunduğumuz yerler zararlı uygulamanın sahte ekranı oluyor.

Örneđin, telefona indirdiğimiz masum görünümlü bir el feneri uygulaması düşünelim. Biz banka uygulamasını açtığımız anda, bu el feneri uygulaması bankanın birebir aynısı olan sahte bir şifre giriş ekranını uygulamanın tam üstüne oturtuyor. Biz de bankaya giriş yapıyorum sanıp şifreyi yazıyoruz ve bilgiler doğrudan saldırganın eline geçiyor.

c) Root / Jailbreak

Normal bir telefonda her uygulama kendi sandbox adı verilen güvenli kutusunda çalışır ve başka uygulamanın dosyalarına erişemez. Ancak cihaz root edilmişse veya jailbreak yapılmışsa, işletim sisteminin bu güvenlik duvarları ortadan kalkar. Yönetici hakları açıldığı için herkes her şeye erişebilir hale gelir.

Bunun en tehlikeli örneđi veri hırsızlıđıdır. Cihaz rootluyrsa, bir saldırgan basit bir dosya yöneticisiyle gidip uygulamamızın arka planda sakladığı gizli dizinlere girebilir. Buradaki şifresiz

ayarları kopyalayabilir, hatta uygulamanın o an bellekte çalışan halini dondurup içinden şifreleme anahtarlarını bile sızdırabilir.

d) SQLite ve şifreleme

Mobil uygulamalar verilerini genelde cihazdaki SQLite veritabanlarında saklar. Eğer kullanıcı şifresi veya oturum bilgileri bu veritabanında düz metin olarak tutuluyorsa büyük bir güvenlik açığı ortaya çıkar. Telefon çalındığında ya da rootlu bir cihaza sızıldığında, dosyayı bulan biri standart bir SQLite okuyucu programla tüm verileri açıkça görebilir.

Eğer SQLCipher gibi bir çözüm kullanırsak işler değişir. SQLCipher, veritabanı dosyasının tamamını 256-bit AES ile şifreler. Bu sayede dosya kopyalansa bile, doğru şifreye sahip olmayan biri için içi anlamsız, çöp karakterlerle dolu bir metin olarak görünür.

e) Access Token ve Refresh Token

Bu ikisini aslında bir konsere girerken kullanılan bilet sistemine benzetebiliriz. Access Token, içeri girmemizi sağlayan ve görevliye sürekli gösterdiğimiz günlük yaka kartımız. Refresh Token ise o yaka kartının süresi bittiğinde yenisini gidip alabildiğimiz abonelik belgemiz.

Access Token neden kısa süreli tutulur? Çünkü Access Token'ı çok sık kullanırız; sunucuya yaptığımız her istekte onu da göndeririz. Bu kadar ortalıkta dolaşan bir verinin araya girilip çalınma riski çok daha yüksektir. Çalınsa bile alan kişinin elinde patlasın, sadece çok kısa bir süre kullanabilsin diye ömrünü kısa tutarız.

Refresh Token neden daha güvenli yerde saklanmalı? Çünkü Refresh Token, süresi biten Access Token'ın yerine yeni bir yaka kartı çıkartabilme gücüne sahiptir. Eğer biri bunu ele geçirirse, sürekli yeni token üretip sistemde sonsuza kadar dolaşabilir. Bu yüzden çok daha güvenli bir şekilde saklanması gerekir.

Çıkış yapıldığında neden Refresh Token iptal edilir? Kullanıcı çıkış yaptığında artık o cihazın sistemle olan bağının tamamen kesilmesi gerekir. Refresh Token'ı sunucu tarafında iptal ederiz ki, cihazı alan veya eski token'ı bulan biri gidip bana yeni access token ver diyerek kapıyı tekrar açmasın.